

R27

HTB · STARTING POINT

HTB Starting Point — Appointment

Programación para Ciberseguridad · Fase III · AD2026

SQL Injection es una de las vulnerabilidades web más antiguas y frecuentes. Esta máquina de Tier 1 expone un formulario de login vulnerable a SQLi — la misma técnica documentada en el OWASP Top 10 desde hace más de dos décadas.

Objetivo: Explotar una inyección SQL básica en un formulario de login para acceder sin credenciales válidas y recuperar la flag.

Acceso a la plataforma

Ve a Starting Point → Tier 1 → Appointment e inicia la máquina.

Pistas de enfoque

Escanea con **nmap**. Ve al servidor web en el navegador. En el campo de usuario del login, prueba payloads básicos de SQLi como `' OR '1'='1` o `admin'--`. Una vez autenticado, encuentra la flag.

Evidencias requeridas

- Screenshot del payload de SQLi que funcionó en el formulario de login.
- Screenshot de la flag encontrada.

Preguntas de reflexión

1. La inyección SQL funciona porque el servidor construye la consulta concatenando directamente la entrada del usuario. ¿Cómo lo solucionarían las *prepared statements* o las *parameterized queries*?
2. Este ataque no requirió Python — se hizo desde el navegador. ¿Cómo automatizarías con **requests** un ataque de fuerza bruta de payloads SQLi contra cien URLs distintas?
3. SQLi aparece en el OWASP Top 10 desde el año 2003. ¿Por qué crees que sigue siendo tan prevalente si la solución técnica es bien conocida?